

9.6 安全管理措施

目前，信息已成为人类的重要资产，由于计算机和网络技术的迅猛发展而带来的安全问题正变得日益突出，使得企业在业务运作过程中，面临巨大的信息资产泄露风险，信息基础设施也面临着大量存在于组织内外的各种威胁。因此，对信息系统需要加以严格管理和妥善维护，安全管理也随之产生。

安全管理是保护国家、组织和个人等各个层面上信息安全的重要基础。只有以有效的安全管理体系为基础，完善安全管理结构，综合应用安全管理策略和安全技术产品，才有可能建立起一个真正意义上的安全防护体系。安全管理应当涉及系统安全的各个方面，包括制定安全策略、风险评估、控制目标与方式选择、制定规范的操作流程、对人员进行安全培训等一系列工作。

9.6.1 安全管理的内容

安全管理体系是企业在整体或特定范围内建立的系统安全方针和目标，以及完善这些目标所采用的方法和手段所构成的体系，是安全管理活动的直接结果，可表示为策略、原则、目标、方法、程序和资源等总体集合。

1. 密码管理

为了保护计算机和信息系统中的敏感信息，有选择地采取技术上的和相关程序上的安全防护措施，是企业在安全管理体系中的迫切需求。使用基于密码机制的安全系统来保护敏感信息是行之有效的方法。被保护信息的机密性和完整性等安全特性由相应密码模块的功能来实现。因此，将密码模块置于系统中，以及相应的密码管理就显得尤为重要。

2. 网络管理

从功能上来看，网络管理一般包括配置管理、性能管理、安全管理、计费管理和故障管理等。由于网络安全对信息系统的性能、管理的关联和影响趋于更复杂、更严重，网络安全管理逐渐成为网络管理中的一个重要分支，正受到业界和用户的日益深切的广泛关注。

目前，在网络应用的深入和技术频繁升级的同时，非法访问、恶意攻击等安全威胁也在不断推陈出新，愈演愈烈。防火墙、VPN、IDS、防病毒、身份认证、数据加密、安全审计等安全防护和管理系统在网络中得到了广泛应用。虽然这些安全产品能够在特定方面发挥一定的作用，但是这些产品大部分功能分散，各自为战，形成了相互没有关联的、隔离的“安全孤岛”；各种安全产品彼此之间没有有效的统一管理调度机制，不能互相支撑、协同工作，从而使安全产品的应用效能无法得到充分发挥。比较理想的网络管理需要建立一个整体网络安全管理解决方案，以便总体配置和调控整个网络多层面、分布式的安全系统，实现对各种网络安全资源的集中监控、统一策略管理、智能审计和多种安全功能模块之间的互动，从而有效简化网络安全管理工作，提升网络的安全水平、可控制性和可管理性，降低用户的整体安全管理开销。

3. 设备管理

对设备的安全管理是保证信息系统安全的重要条件。设备安全管理包括设备的选型、检测、

安装、登记、使用、维护和存储管理等方面的内容。设备管理的不安全可能带来灾难性的后果。

为了保障信息系统的物理安全，对系统所在环境的安全保护，应遵守相关国家标准，例如，电子计算机机房设计规范、计算站场地技术条件、计算站场地安全要求等；网络设备、设施应配备相应的安全保障措施，包括防盗、防毁和防电磁干扰等，并定期或不定期地进行检查。

4. 人员管理

信息系统是由人来开发的，也是为人类服务的。影响信息系统安全的因素，除了少数难以预知和不可抗力的自然因素以外，绝大多数的安全威胁来自于人类自己。例如，对信息系统进行攻击和破坏的黑客和计算机病毒，以及操作失误等。因此，人始终是影响信息系统安全的最大因素，人员管理也就成为信息系统安全管理的关键。全面提高信息系统相关人员的技术水平、道德品质和安全意识等是信息系统安全的重要保证。

制定安全措施、标准、原则和实施过程，仅仅是有效的信息安全计划的开始。如果不能切实保证参与人员都能意识到自己的权利和责任，再强大的安全体系也是徒劳的。许多安全事件都是由内部人员引起的，因此，人员的素质和人员的管理是十分重要的。人员管理的核心是要确保有关业务人员的思想素质、职业道德和业务技能。

9.6.2 安全审计

安全审计是指由专业审计人员根据有关的法律法规、财产所有者的委托和管理当局的授权，对计算机网络环境下的有关活动或行为进行系统的、独立的检查验证，并作出相应评价。安全审计对主体访问和使用客体的情况进行记录和审查，以保证安全规则被正确执行，并帮助分析安全事故产生的原因。

安全审计是落实系统安全策略的重要机制和手段，通过安全审计，识别与防止系统内的攻击行为、追查系统内的泄密行为。它是系统安全保障系统中的一个重要组成部分。显然，安全审计作为一个专门的审计项目，要求审计人员必须具有较强的专业技术知识与技能。

1. 安全审计的基本要素

安全审计涉及4个基本要素，分别是控制目标、安全漏洞、控制措施和控制测试。

(1) 控制目标。控制目标是指企业根据具体的计算机应用，结合单位实际制定出的安全控制要求。

(2) 安全漏洞。安全漏洞是指系统的安全薄弱环节，容易被干扰或破坏的地方。

(3) 控制措施。控制措施是指企业为实现其安全控制目标所制定的安全控制技术、配置方法及各种规范制度。

(4) 控制测试。控制测试是将企业的各种安全控制措施与预定的安全标准进行一致性比较，确定各项控制措施是否存在、是否得到执行、对漏洞的防范是否有效，评价企业安全措施的可依赖程度。

2. CC 标准

由ISO提出的通用准则(Common Criteria, CC)将安全审计功能分为6个部分，分别是安